

Checklist de riesgos de negocio adicionales

Sterclicks — Más allá de RGPD y ciberseguridad técnica

Este documento complementa el informe de cumplimiento normativo y el checklist técnico ya elaborados, cubriendo áreas de riesgo adicionales para el negocio: propiedad industrial, seguridad de producto, fiscalidad, dominio/email, dependencias técnicas, accesos de terceros y continuidad de negocio.

Prioridad alta: revisar cuanto antes el uso de la marca “Playmobil” en la web y materiales, y la configuración SPF/DKIM/DMARC del dominio — son los dos puntos con mayor riesgo inmediato de esta lista.

1. Propiedad industrial e intelectual

- Revisar todo el sitio (textos, metadatos SEO, tags, nombre de dominio, redes sociales) en busca de menciones directas a la marca registrada “Playmobil”.
- Sustituir referencias directas por descripciones genéricas (“figuras personalizadas de bloques”, “estilo minifigura”) que no invoquen la marca registrada.
- Revisar si algún render, foto de producto o modelo 3D reproduce piezas o diseños escaneados directamente de figuras Playmobil originales (riesgo de infracción de diseño industrial, no solo de marca).
- Confirmar que el modelado en Blender parte de mediciones propias (calibre) y referencias fotográficas propias, no de archivos STL de terceros con derechos reservados.
- Revisar términos de uso de cualquier recurso externo (texturas, fuentes, iconos, música en vídeos promocionales) para confirmar licencia de uso comercial.

2. Seguridad de producto físico (normativa de juguetes)

- Decidir y documentar el posicionamiento del producto: ¿figura decorativa/coleccionable para adultos, o juguete para niños? Esto determina el régimen normativo aplicable.
- Si se posiciona como coleccionable para adultos, verificar que la publicidad, fotos y descripciones son coherentes con ese público (no mostrar ni sugerir uso infantil).
- Si existe posibilidad de compra para niños, revisar aplicabilidad del Reglamento (UE) de Seguridad de los Juguetes: marcado CE, advertencias de piezas pequeñas/riesgo de asfixia, edad mínima recomendada visible en ficha de producto.
- Revisar si el proceso de impresión en resina (Elegoo Saturn 4 Ultra) requiere información adicional sobre materiales o acabados en la ficha de producto (algunas resinas no son aptas para contacto prolongado con la piel o boca).

3. Fiscalidad y facturación

- Verificar adaptación a Verifactu (sistema de facturación electrónica verificable), de implantación progresiva para autónomos y pymes en España.
- Comprobar el tratamiento correcto del IVA en ventas a otros países de la UE: aplicación del régimen OSS (One Stop Shop) si se superan los umbrales de venta a distancia intracomunitaria.

- Revisar el plazo legal de conservación de facturas (con carácter general 4 años a efectos fiscales, hasta 6 según la Ley del IVA) y dónde se almacenan (¿mismo backup que la BD, o sistema aparte?).
- Confirmar que los datos fiscales del cliente (NIF, dirección de facturación) reciben el mismo nivel de protección que el resto de datos personales.

4. Seguridad de dominio y email

- Configurar registro SPF en el DNS del dominio, autorizando explícitamente los servidores que pueden enviar correo en nombre de sterclinks.com (Hostinger + Brevo).
- Configurar DKIM para firmar digitalmente los correos salientes (Brevo lo facilita desde su panel al verificar el dominio).
- Configurar política DMARC (al menos en modo p_none para monitorizar, evolucionando a p_quarantine/p_reject) para evitar suplantación del dominio en phishing.
- Activar renovación automática del dominio y del certificado SSL, con alerta previa a la fecha de expiración.
- Habilitar autenticación de dos factores en el panel de Hostinger, en la cuenta de Brevo y en el registrador del dominio (no solo en el panel de admin de Sterclinks).

5. Dependencias técnicas y superficie de ataque

- Ejecutar 'composer audit' periódicamente para detectar dependencias PHP con vulnerabilidades conocidas.
- Revisar la versión de CodeIgniter 4 y de PHP en uso frente a las versiones soportadas actualmente con parches de seguridad activos.
- Evaluar activar Cloudflare (plan gratuito) o el WAF que ofrezca Hostinger delante del dominio, como capa adicional de protección frente a bots y ataques comunes.
- Revisar dependencias de Node/npm si el frontend usa alguna build tool, con 'npm audit'.

6. Accesos de colaboradores y terceros

- Documentar (aunque sea de forma sencilla) un acuerdo de confidencialidad con Esther respecto a datos de clientes y código del proyecto.
- Revisar los permisos reales de Esther en Hostinger, Git, panel de admin y cualquier servicio conectado: aplicar principio de mínimo privilegio (acceso solo a lo que necesita para su función, no acceso total por defecto).
- Revisar accesos de Claude Code y otras herramientas de IA al repositorio: confirmar que no hay credenciales, claves de API o el .env expuestos en el historial de commits o en archivos que Claude Code pueda leer/subir accidentalmente.
- Establecer un proceso simple para revocar accesos si cambia la relación con algún colaborador (cambiar contraseñas compartidas, revocar API keys, etc.).

7. Continuidad de negocio

- Confirmar que existe un lugar seguro (gestor de contraseñas) con todas las credenciales críticas: panel de Hostinger, registrador de dominio, Brevo, Backblaze, repositorio Git, pasarela de pago.

- Definir qué ocurre si se pierde acceso a la cuenta de Hostinger o al dominio: ¿hay un contacto de recuperación, email de respaldo y teléfono actualizados en cada servicio?
- Verificar que el sistema de backups ya desarrollado (BackupService) se prueba periódicamente con una restauración real, no solo se confirma que el archivo se sube correctamente.
- Evaluar la contratación de un seguro de responsabilidad civil para el negocio, especialmente relevante al vender producto físico que podría llegar a manos de menores.

8. Redes sociales y separación de actividad personal/comercial

- Si se promociona Sterclicks desde una cuenta personal de Instagram, revisar que quede claro cuándo se trata de contenido comercial (relevante también desde la perspectiva de la CNMC para microempresas/creadores que venden producto).
- Evitar mezclar datos de clientes de Sterclicks (mensajes directos, pedidos gestionados por Instagram) con la actividad personal de fotografía — si se gestionan pedidos por DM, esos datos también caen bajo las mismas obligaciones de RGPD que la web.

Documento de trabajo interno. Los puntos de propiedad industrial, seguridad de producto y fiscalidad conviene contrastarlos con un abogado y/o gestor especializado; no sustituyen asesoramiento profesional.